

Modern Software Practices

A Condensed Guide

The DoW software modernization, DevSecOps, open source and cATO documents, condensed for systems engineers and program teams • October 2026

Modern Software Practices

A Condensed Guide

The Department of War software modernization, DevSecOps, open source and continuous authorization documents, as of October 2026

October 2026

Read this first

This is an unofficial condensation. The originals govern. It summarizes nineteen publicly listed documents of the Department of War Chief Information Officer (DoW CIO) library, as linked on 3 October 2026 and read in the copies listed, with their SHA-256 checksums, in Appendix B. It adds no requirement of its own. Where it says what a document means for a small systems-engineering team, the box is marked *For a small MBSE team* and that reading is this guide's, not the Department's.

Names. The Department of Defense now styles itself the Department of War. Documents published before the change say "DoD"; the library now lists several of them under "DoW" titles. This guide uses each document's own name and the library's title for it.

Citations. "(Fundamentals p. 12)" means page 12 of the PDF file, counting the cover as page 1, which is not always the number printed on the page. The short names are listed in Table 2.1.

Status words. *Policy* binds (an instruction or a signed memorandum). *Guidance* explains and recommends. A *report* records findings. *Draft* is marked pre-decisional by the document itself. Several 2021 documents print "This document automatically expires 1-year from publication date unless revised"; they are still listed in the library, and this guide flags them.

One marking to respect. The cATO Implementation Guide carries Distribution Statement C on its cover although it also bears an open-publication clearance stamp and is posted in the public library. This guide summarizes it at a high level only. Ask your security office before redistributing that original.

Contents

1 Bottom line up front **1**

2 How the documents fit together **2**

3 Modern software practices: strategy, plan, policy **5**
3.1 DoW Software Modernization Strategy 5
3.2 Software Modernization Implementation Plan, FY25–26 6
3.3 DoWI 8430.01, Accelerated Mission Software 6
3.4 Memo: Accelerating Secure Software 8
3.5 Software Fast Track RFI Combined Summary 9

4 The DevSecOps document set **10**
4.1 DoW Enterprise DevSecOps Fundamentals 10
4.2 Activities & Tools Guidebook and workbook 11
4.3 DevSecOps Playbook 13
4.4 The State of DevSecOps 13

5 DevSecOps reference designs **14**
5.1 Pathway to a Reference Design 14
5.2 The four designs side by side 14
5.3 The Azure + GitHub draft in more detail 15

6 Open source software **17**

7 Continuous authorization to operate **19**
7.1 The memo 19
7.2 The evaluation criteria and the implementation guide 19
7.3 Checklist 20

8 What it means for a small MBSE team **22**

9 What to read in full, and when **24**

A Glossary of acronyms **25**

B Sources **27**

CHAPTER

1

Bottom line up front

Ten things a program team should know before reading any of the nineteen documents.

1. **There is now an instruction.** DoWI 8430.01, *Accelerated Mission Software*, effective 8 September 2026, applies to all software throughout its lifecycle in every DoW Component, acquisition and non-acquisition programs alike, regardless of dollar value (DoWI 8430.01 p. 1, 4). Everything else in this guide is older and either directs one topic (the memos) or explains (guidance and reports).
2. **The direction is the same in every document:** small cross-functional teams, CI/CD pipelines, automation, security built in, continuous feedback from users (DoWI 8430.01 p. 13–15), (Fundamentals p. 9–10). "Treat testing, security scanning, compliance checks, and deployment as continuous activities, not final gates" (DoWI 8430.01 p. 14).
3. **Pipelines are critical infrastructure.** Component heads "operate secure, automated CI/CD pipelines" and treat them as infrastructure that "must be authorized, monitored, and protected" (DoWI 8430.01 p. 9).
4. **Evidence is machine-readable.** All software on DoW networks is to be supported by machine-readable evidence of its composition, build integrity and application security; an accurate SBOM for all covered software; provenance and attestations from an automated build (DoWI 8430.01 p. 18).
5. **The vocabulary is the Fundamentals.** Ten lifecycle phases (Plan to Feedback), software factory, DevSecOps platform, CI/CD pipeline, Infrastructure as Code (Fundamentals p. 9–12).
6. **The checklist is the Activities & Tools Guidebook.** Its REQUIRED activities "are not negotiable"; a reference design may add activities or raise PREFERRED to REQUIRED, never lower one (Guidebook p. 6, 10).
7. **Only two reference designs are approved.** CNCF Kubernetes (2021) and CNCF Multi-Cluster Kubernetes (2022). The AWS and the Azure + GitHub designs are drafts (RD-AWS p. 1), (RD-Azure p. 2).
8. **cATO is a privilege on top of an ATO.** It needs an existing ATO in the RMF monitor step, continuous monitoring, active cyber defense and an approved reference design; the DoD CISO approves it (cATO memo p. 1–3), (cATO criteria p. 6, 8).
9. **Measure the value stream; use DORA metrics inside the team.** DORA metrics "are not appropriate to compare beyond the team context"; enterprise reporting focuses on value streams and mission outcomes (DoWI 8430.01 p. 16).
10. **Open source and AI have rules.** Adopt, buy, then create (OSS memo p. 3); assess third-party and open source components on sustainment, source, dependencies, security, integrity and foreign influence (DoWI 8430.01 p. 22); AI-generated code is "unverified input" and non-public information stays out of unapproved AI services (DoWI 8430.01 p. 23).

> **For a small MBSE team: the short version**
>
> Use an existing DevSecOps platform; keep the model and its pipeline in it; let the pipeline produce the evidence (tests, scans, SBOMs, the verification matrix) on every change; report value-stream measures upward and keep DORA numbers inside the team.

CHAPTER

2

How the documents fit together

The library groups the documents under five headings. Read top-down, they form a chain: a strategy sets goals, an implementation plan assigns tasks, an instruction makes them policy, the fundamentals give the vocabulary, the guidebook and playbook give the activities, the reference designs give tested architectures, and the cATO documents say how a platform built that way is authorized continuously.

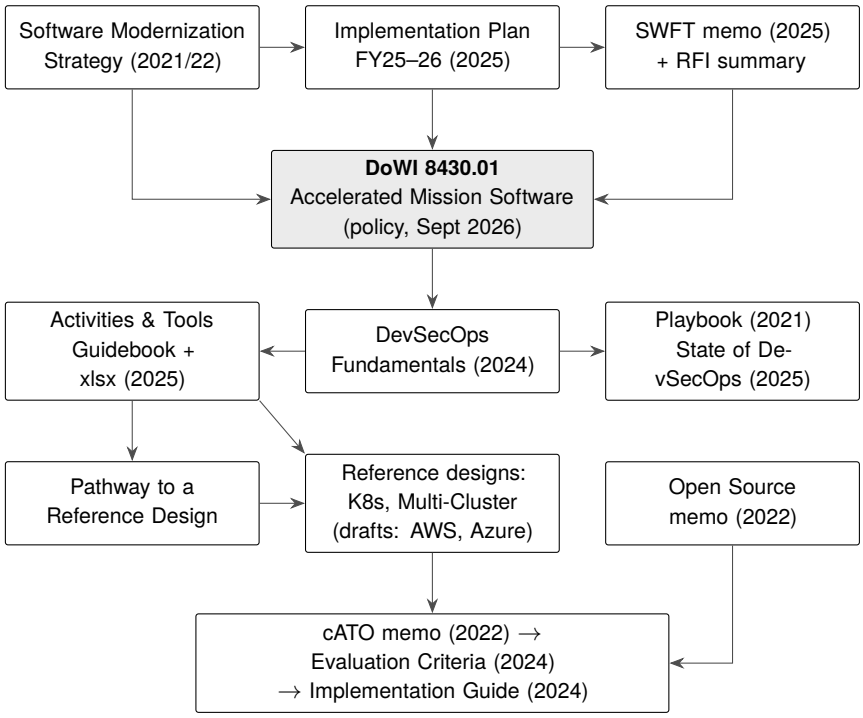


Figure 2.1: How the nineteen documents relate (this guide's reading). Arrows point from the document that sets direction to the one that implements or depends on it.

Table 2.1: The nineteen documents: short name used in this guide, date, status.

Document (library title)	Short name	Date	Status
Modern Software Practices			
DoW Software Modernization Strategy	Strategy	Nov 2021; memo 1 Feb 2022	Strategy, directed by DepSecDef memo
Software Modernization Implementation Plan FY25–26	I-Plan	cleared Apr 2025	Plan (tasks); some pages carry inconsistent footer markings
DoWI 8430.01, Accelerated Mission Software	DoWI 8430.01	effective 8 Sep 2026	POLICY instruction
Memo: Accelerating Secure Software	SWFT memo	24 Apr 2025	POLICY memo (directs SWFT)
Software Fast Track RFI Combined Summary	SWFT RFI	cleared Dec 2025	Report of industry responses, not an endorsement
DevSecOps document set			
DoW Enterprise DevSecOps Fundamentals	Fundamentals	v2.5, Oct 2024	Guidance (approved by the SSG)
DoW Enterprise DevSecOps Activities & Tools Guidebook	Guidebook	v2.5, Apr 2025	Guidance with a REQUIRED baseline
DevSecOps Fundamentals Guidebook: Activities & Tools (xlsx)	Workbook	companion of v2.5	The guidebook's tables as a workbook
DevSecOps Playbook	Playbook	v2.1, Sep 2021	Guidance; SELF-EXPIRY printed on cover
The State of DevSecOps Report	State report	Mar 2025	Report (findings)
DevSecOps reference designs			
Pathway to Reference Design	Pathway	Sep 2021	Process description
Reference Design: CNCF Kubernetes	RD-K8s	v2.1, Sep 2021	Approved design; SELF-EXPIRY printed
Reference Design: CNCF Multi-Cluster Kubernetes	RD-Multi	v1.0, Jul 2022	Approved design
DRAFT: DOW AWS Managed Service	RD-AWS	v0.2, Sep 2021	DRAFT; approval "TBD"; SELF-EXPIRY
DRAFT: DOW Cloud IaC + GitHub + Azure	RD-Azure	v0.01, Sep 2022	DRAFT (signed, marked pre-decisional)
Open source software			

Document (library title)	Short name	Date	Status
Software Development and Open Source Software Memorandum	OSS memo	24 Jan 2022	**POLICY** memo
Continuous authority to operate			
Memo: Continuous Authorization to Operate (cATO)	cATO memo	2 Feb 2022	**POLICY** memo (DoD SISO)
cATO Evaluation Criteria (DevSecOps use case)	cATO criteria	29 May 2024	Criteria; "living document" on the RMF KS
DevSecOps Continuous Authorization Implementation Guide	cATO guide	v1.0, Mar 2024	Guidance; cover marked Distribution C

Version drift between the documents

The documents cite each other by version, and the versions moved on. The CNCF Kubernetes design asserts compatibility with the Strategy Guide and the Tools and Activities Guidebook *version 2.1* (RD-K8s p. 8); the current guidebook is version 2.5 (Guidebook p. 1). The cATO guide cites the Fundamentals version 2.1 and the guidebook version 2.2 (cATO guide p. 26). When two documents disagree on a detail, the later document and the instruction win; for an authorization, ask your AO which version they assess against.

CHAPTER

3

Modern software practices: strategy, plan, policy

3.1 DoW Software Modernization Strategy

What it is. The DoD Software Modernization Strategy, version 1.0 of November 2021, approved by the Deputy Secretary of Defense in a memo of 1 February 2022 (Strategy p. 1–2). It is a sub-strategy of the Digital Modernization Strategy and replaces the DoD Cloud Strategy (Strategy p. 3). Audience: Department leadership and everyone who plans software work.

Key points.

- Vision: "Deliver Resilient Software Capability at the Speed of Relevance"; resilience means high-quality and secure software (Strategy p. 5–6).
- Five unifying principles: Primacy of Security, Stability, and Quality at Speed; Cloud Smart/Data Smart; Enterprise First; No One Left Behind; More Than Code (contracting, intellectual property, transition to fielding) (Strategy p. 6).
- Software is adopted, bought or created, and "software delivery is not a one-and-done activity" (Strategy p. 7).
- The framework pairs technical enablers (enterprise cloud, design patterns, DevSecOps tooling, enterprise services) with process transformation (business operations, acquisition, cyber survivability, testing, workforce) (Strategy p. 7–9). A software factory is "a software assembly plant" with multiple pipelines producing deployable artifacts "with minimal human intervention" (Strategy p. 8).
- "Cybersecurity should be the driver and compliance an outcome" (Strategy p. 9).
- Three goals: accelerate the enterprise cloud environment (including automated design patterns such as Infrastructure as Code, Compliance as Code and hardened containers) (Strategy p. 10–11); establish a Department-wide software factory ecosystem (including continuous authorization, where cyber professionals work with developers *and system engineers* to identify pipeline-generated evidence) (Strategy p. 11–12); transform processes (policy, agile acquisition, software as data, workforce) (Strategy p. 12–13).
- The CIO and the Under Secretaries for A&S and R&E lead through a Software Modernization Senior Steering Group (SSG) (Strategy p. 1, 14).

Requires or recommends. A strategy: it sets direction and tasks the SSG; it does not itself bind programs.

3.2 Software Modernization Implementation Plan, FY25–26

What it is. The task list that carries the strategy forward, cleared for publication in April 2025 (I-Plan p. 1). Of the 41 tasks in the FY23–24 plan, 27 were accomplished, 12 carried over and 2 combined (I-Plan p. 4). Audience: those responsible for an organization's software strategy, developers and operators, and leaders (I-Plan p. 5).

Tasks that matter to a program team (the plan lists them under the strategy's three goals, not in priority order (I-Plan p. 6)):

- a quick-track Software-as-a-Service ATO process (I-Plan p. 7);
- scale modern software practices, including a DevSecOps platform and software factory catalog and DoD-wide software assurance capabilities (I-Plan p. 9);
- developer tools (web.git.mil, digital engineering for software development, Infrastructure as Code for the cloud contract's capabilities and at IL6) (I-Plan p. 10);
- cATO "must become a standard business practice": designate cATO platforms, publish analytics, train authorizing officials (I-Plan p. 11);
- prepare software factories for AI: data provenance, AI traceability, risk assessment, AI/ML DevSecOps guidance (I-Plan p. 12);
- secure software standards: the NIST Secure Software Development Framework (SSDF) is already integrated into the Activities and Tools guidebook; secure coding practices and metrics, secure container standards and an SBOM repository pilot are next (I-Plan p. 14);
- modernize JCIDS for DevSecOps, "oftentimes the root cause is unclear requirements", with recommended metrics such as DORA metrics (I-Plan p. 14);
- software modernization in embedded weapons systems (Weapons Ignite toolkit) (I-Plan p. 15); more use of the Software Acquisition Pathway, whose adoption grew about 50% a year (I-Plan p. 16); a software cadre and eight software engineering work roles (I-Plan p. 13, 16–17).

3.3 DoWI 8430.01, Accelerated Mission Software

What it is. The DoW instruction on software modernization and management, approved 31 August 2026 by the DoW CIO and effective 8 September 2026 (DoWI 8430.01 p. 1). It applies to all software throughout its lifecycle except research and prototype funding (budget activities 1–4) until that software transitions to acquisition or operations (DoWI 8430.01 p. 4). **POLICY**

3.3.1 Policy in one page

Software is "a strategic asset to be managed as an enduring capability throughout its lifecycle" (DoWI 8430.01 p. 4). DoW software efforts:

(1) employ modern, secure, human-centric practices such as Agile and DevSecOps;
(2) use "measurable and testable requirements that are traceable to mission critical functions", including cybersecurity, cyber resilience and zero trust suitability;
(3) use component analysis, telemetry, observability and automated monitoring;
(4) prefer existing software, open source, COTS and SaaS before developing anything new;
(5) examine business processes before developing software (DoWI 8430.01 p. 4–5).

3.3.2 The seven tenets

Table 3.1: Modern software tenets (DoWI 8430.01 p. 13–15).

Tenet	What it asks
Embrace change through continuous feedback	Software is never done; CI/CD and frequent deployment of working software are "the primary mechanism for refining requirements".
Optimize for flow, not phases	Remove friction; small, cross-functional, mission-focused teams decide technical choices, workflows and tooling within architecture and security baselines.
Build security and quality in, not on	The whole team owns it; approved reference designs, enterprise platforms and provisionally authorized IaC "make the secure path the easy path".
Automate to the greatest extent possible	Testing, scanning, compliance checks and deployment are continuous, "not final gates"; feedback on every code change.
Architect for evolvability and scale	Loosely coupled, highly cohesive, modular, well-defined APIs, containers; simplicity and testability.
Default to enterprise reuse	Source, documentation, APIs, data schemas and SBOMs discoverable with unlimited (else government purpose) rights; military or space software is CTI from inception.
Align governance with speed	Adapt acquisition, cyber and T&E processes; delegate decisions to the lowest practical level; verify through automated evidence.

3.3.3 What it requires of a program

- **Pipelines.** Operate secure, automated CI/CD pipelines as critical infrastructure (DoWI 8430.01 p. 9).
- **Assurance evidence.** Static and dynamic analysis, fuzz testing, penetration testing and secure-code reviews, with continuous authorization strategies from inception (DoWI 8430.01 p. 10).
- **Supply chain.** SBOMs generated for custom software and captured for COTS; provenance and pedigree tracked (DoWI 8430.01 p. 10). A secure, automated, observable build that emits machine-readable provenance and attestations (DoWI 8430.01 p. 18). All third-party components, including transitive dependencies, in the SBOM (DoWI 8430.01 p. 23).
- **Users.** Human-centered design, regular contact with representative users, usage and satisfaction telemetry, value stream metrics in recurring product reviews (DoWI 8430.01 p. 10).
- **Test.** Integrated, continuous T&E that unifies DT&E and OT&E; DT&E follows the DevSecOps Activities and Tools Guidebook; adversarial testing covers pipelines, IaC scripts, source repositories and running applications; findings go into the backlog and are tracked to remediation; periodic independent government cyber DT&E is still required (DoWI 8430.01 p. 19–20). Testers accept validated automated artifacts, scans, performance data and telemetry as evidence (DoWI 8430.01 p. 9).

- **Security baseline.** Factories in the enterprise digital arsenal are authorized at least moderate confidentiality and integrity; cloud hosting at IL2 or higher; software and technical artifacts with a military or space application (source, build scripts, SBOMs, test vectors, design documents) are CTI at moderate/moderate (DoWI 8430.01 p. 20).
- **Common security requirements** in eight areas: secure architecture, authentication and authorization, input validation, FIPS-validated cryptography, error handling and logging, software safety, operational resilience, continuous vulnerability management with analysis and dependency scanning in pipelines (DoWI 8430.01 p. 20–21).
- **Measurement.** Value stream metrics across the full lifecycle; team metrics such as DORA are leading indicators "not appropriate to compare beyond the team context"; contracts give the government access to the metrics data in contractor environments (DoWI 8430.01 p. 15–16).
- **Reuse and release.** Report custom code (DITPR for unclassified); share it in a repository after removing PII and sensitive data "from code, documentation, issues, and commit history"; military or space code is shared by InnerSource; other code may be released as open source under permissive, widely recognized licences (DoWI 8430.01 p. 25–26).
- **Acquisition.** The Software Acquisition Pathway (DoDI 5000.87) is "the preferred pathway for all DoW software acquisition"; commercial solutions openings and other transactions are the default solicitations (DoWI 8430.01 p. 27).

3.3.4 AI in software development

Developers stay fully accountable; security- or safety-critical AI-generated changes need human review and approval; AI-generated code is "unverified input"; non-public DoW information — code, configuration scripts, infrastructure definitions, schematics, documentation — may not go into generative AI unless the service resides on DoW information systems and is approved; AI code gets the same review and testing as other code, including intellectual property and licence checks; only approved AI services, which must not train on government data or prompts and must be auditable; keep a record of models, versions and datasets in the evidence package "analogous to the SBOM" (DoWI 8430.01 p. 23–25).

> **For a small MBSE team: DoWI 8430.01**
>
> A model repository in GitLab with a pipeline is already most of tenets (a), (c) and (d). The instruction's phrase "requirements that are traceable to mission critical functions" is the requirement-to-verification trace a SysML v2 model keeps (Primer: *The pipeline, job by job*). The AI rules apply to a local model assistant too: keep the model on an approved system, review what it writes, and record which model wrote it (Primer: *A local AI assistant on the laptop*). Removing sensitive data "from ...commit history" before sharing is a reason to keep it out of the history in the first place.

3.4 Memo: Accelerating Secure Software

What it is. A one-page memo of 24 April 2025 by the official performing the duties of the CIO, directing a Software Fast-Track (SWFT) initiative (SWFT memo p. 1). **POLICY**

It names the problem plainly: "Lengthy, outdated cybersecurity authorization processes frustrate agile, continuous delivery", and the Department "lacks visibility into the origins and se-

curity of software code". SWFT is to define clear cybersecurity and supply chain risk management requirements, rigorous software security verification, secure information sharing, and government-led risk determinations to expedite authorizations; the framework and plan were due within 90 days (SWFT memo p. 1).

3.5 Software Fast Track RFI Combined Summary

What it is. An analysis of 420 industry responses to three requests for information on supply chain security tools, external assessment, and automation and AI, cleared in December 2025 (SWFT RFI p. 1, 3). It "does not represent an endorsement …nor dictate what a SWFT implementation plan will encompass" (SWFT RFI p. 7), and it says it was partially assisted by generative AI with human review (SWFT RFI p. 1). **REPORT**

Findings worth knowing. NIST SP 800-218 (SSDF) appeared in over 75% of responses, OWASP material in 66%, NIST SP 800-53 in 60%, NIST SP 800-161 in 46% (SWFT RFI p. 7); respondents asked the Department to define what a valid SSDF attestation is (SWFT RFI p. 8); 90% would provide an SBOM (SWFT RFI p. 10); risk artifacts mapped to the RMF body of evidence (SAR, SSP, RAR, POA&M) (SWFT RFI p. 11–12); for SBOMs, standardized machine-readable formats such as CycloneDX or SPDX, package URLs, licences, provenance and dependency relationships (SWFT RFI p. 26).

CHAPTER

4

The DevSecOps document set

4.1 DoW Enterprise DevSecOps Fundamentals

What it is. An "educational compendium" approved by the SSG on 16 October 2024 (Fundamentals p. 3, 7), for novice and intermediate staff and for managers and leaders (Fundamentals p. 7).
GUIDANCE

Definition. DevSecOps is "a combination of software engineering methodologies, practices, and tools that unifies software development (Dev), security (Sec), and operations (Ops)" with collaboration, automation and continuous monitoring (Fundamentals p. 9). DoWI 8430.01 uses the same definition (DoWI 8430.01 p. 31).

Assumptions. Agile is already in place; approved or provisionally authorized cloud is preferred, with on-premises hardware-in-the-loop testing for weapons systems; "Avoiding vendor lock-in without considering other types of lock-in is ill-advised" (Fundamentals p. 7–8). A DevSecOps implementation "does not require a specific architecture, containers, or even explicit use of cloud computing", though these are strongly recommended and some reference designs mandate them (Fundamentals p. 12).

Implementation components. The software supply chain (four links each 90% secure give roughly 65%; raising each to 95% gives 81%) (Fundamentals p. 12–13); the software factory (infrastructure, digital platform and application capabilities) (Fundamentals p. 13–14); the DevSecOps platform (Fundamentals p. 17–18); CI/CD pipelines (Fundamentals p. 18–20); Infrastructure as Code, which can shorten deployment of networking, identity and security policies "from the standard 30 weeks to hours" (Fundamentals p. 20). A merge request's peer review is "the software code equivalent of two-person integrity" (Fundamentals p. 15); "Released is never equivalent to Deployed!" (Fundamentals p. 16).

Metrics. DORA's four (deployment frequency, change lead time, change failure rate, failed deployment recovery time), Google's four golden signals, the OUSD(A&S) "DoD4" (speed and cadence, stability and reliability, value/ROI, cyber resilience), OKRs and flow metrics (cycle time, throughput, work in progress) (Fundamentals p. 33–35).

Culture. Small incremental changes, security from the start, value open source, engage users early, automate repeated manual work, "Fail fast, learn fast, but don't fail twice for the same reason", documentation close to the code (Fundamentals p. 30–31). Adoption is "a marathon, not a sprint" (Fundamentals p. 37).

4.2 Activities & Tools Guidebook and workbook

What it is. Version 2.5 of April 2025 and its companion spreadsheet, "a single package" (Guidebook p. 1, 6). The spreadsheet is also a template for submitting new reference designs and for "building a continuous ATO package that demonstrates process and responsibility mapping" (Guidebook p. 6). GUIDANCE with a REQUIRED baseline.

The baseline column. REQUIRED activities "are not negotiable" and must be performed within the software factory as part of the minimum viable product release; PREFERRED are aspirational; AS REQUIRED are at the mission owner and AO's discretion (Guidebook p. 6, 10). Reference designs cannot lower REQUIRED to PREFERRED; a contract, requirement or reference design may make an activity AS REQUIRED or not applicable (Guidebook p. 10). Each activity is mapped to the SSDF practice groups PO, PS, PW and RV (Guidebook p. 11). DevSecOps "is most frequently adopted using Scrum 1 and 2 week Sprints" (Guidebook p. 7).

Configuration management. "Without configuration management discipline, DevSecOps practices will not reach their full potential": identification, control (CMDB, source and artifact repositories), and verification and audit as pipeline control gates (Guidebook p. 15–16).

Table 4.1: The ten lifecycle phases (Fundamentals p. 10) and their REQUIRED activities (Guidebook Tables 4–13, PDF pp. 17–52; workbook phase tabs). Mission-based cyber risk assessment and test audit are REQUIRED in nearly every phase and are not repeated.

Phase	Purpose	REQUIRED activities
Plan	Requirements and objectives, focused on the next release	Change management planning; configuration identification; CM planning; DevSecOps process design; documentation version control; IaC deployment; project/release planning; team onboarding planning; risk management; software requirement analysis; system design; test deployment; test plan. (Threat modeling and design review are PREFERRED.)
Develop	Create the elements	Code commit; code commit logging; code commit scan; database component test; documentation; functional test; security code development; static analysis; static code scan before commit; test development; unit test. (Code review is PREFERRED.)
Build	Compile or integrate	API security tests; build; build configuration control and audit; component, functional, integration, regression and software integration tests; dependency vulnerability checking; release packaging; SAST; store artifacts.

Phase	Purpose	REQUIRED activities
Test	Verify against requirements	API security tests; compliance scan; manual security test; regression test; SBOM software composition analysis; service security test; software factory risk continuous monitoring; software integration test; SAST; system test. (DAST and performance test are PREFERRED.)
Release	Package and document	Operational readiness test; release go/no-go decision; SBOM SCA; software factory risk continuous monitoring. (User story review and demonstration is PREFERRED.)
Deliver	Make available to operations	Configuration integration testing; deliver released artifacts; delivery results review; operations team acceptance; SBOM SCA; factory risk monitoring.
Deploy	Install and configure	Compliance tests; interoperability tests; mission-oriented developmental tests; performance tests; post-deployment security scan; SBOM SCA; factory risk monitoring; user evaluation/feedback. (Formal qualification, OT&E and others AS REQUIRED.)
Operate	Use in operations	Business operations; cyber OT&E; logging; SBOM SCA; factory risk monitoring; user evaluation/feedback.
Monitor	Observe and measure	Asset inventory including SBOMs; compliance monitoring (COTS; resources and services); log analysis and auditing; system security monitoring; user evaluation/feedback.
Feedback	Changes for the next iteration	Revise product backlog; user evaluation/feedback.

For a small MBSE team: the guidebook

Several Plan-phase REQUIRED activities are systems engineering by another name: configuration identification, CM planning, risk management, software requirement analysis, system design, test plan. A model-based team that keeps its requirements, design and verification in a configuration-managed model with a pipeline already performs them; map them in the workbook's tailoring columns rather than writing new documents. The Tools tab's "requirements database" asks to "trace requirements to their source" and "trace features or design components to the requirements" — the model's trace (Primer: *DevSecOps in systems-engineering words*).

4.3 DevSecOps Playbook

What it is. Eleven one-page plays with checklists, version 2.1 of September 2021, printed with a one-year self-expiry (Playbook p. 1). **GUIDANCE SELF-EXPIRY**

The plays: adopt a DevSecOps culture ("from 'I' to 'we'") (Playbook p. 4); adopt Infrastructure as Code (vendor lock-in versus product lock-in: cloud-agnostic tools such as Ansible and Terraform "avoid vendor lock-in but create product lock-in"; GitOps = IaC + merge requests + CI/CD) (Playbook p. 5); containerized microservices on CNCF Certified Kubernetes with Iron Bank images, a sidecar security stack and a service mesh (Playbook p. 6); a capability model, not a maturity model (DORA's four key metrics) (Playbook p. 7); 24 key capabilities (Playbook p. 8); establish a software factory — adopt an existing one before building a new, expensive, multi-tenant one (Playbook p. 9); define a meaningful pipeline (start small; "work closely with the AO to understand precisely what each control gate must validate") (Playbook p. 10); agile acquisition ("Do not lock technical requirements into legal contracts") (Playbook p. 11); cyber resilience ("Do not use Fast Track Authority to Operate for software produced by a DevSecOps software factory CI/CD pipeline"; help the AO move to a near real-time dashboard) (Playbook p. 12); shift test and evaluation left ("Establish the plan to automate the collection of test data metrics in the first sprint") (Playbook p. 13); industry practices (Playbook p. 14).

4.4 The State of DevSecOps

What it is. The first DoD CIO report on the state of DevSecOps, March 2025, based on interviews with more than 75 leaders and practitioners in 19 software organizations (State report p. 1, 4). **REPORT**

Findings. Over 50 software factories deliver code to production (State report p. 3); about 78 acquisition programs had adopted the Software Acquisition Pathway, three quarters of them delivering software in under six months (State report p. 10); "Software Factories Are Our Digital Arsenal" (State report p. 4); DevSecOps "must be introduced with leadership commitment" (State report p. 3). On cATO: a system needs an existing ATO and the RMF monitoring stage; authorizing officials are often "biased to caution" rather than "biased to action" (State report p. 27–28); reciprocity is now the default stance "except when cybersecurity risk is too great" (State report p. 29). Policy should be S-P-E-E-E-D: Socialized, Portfolio-wide, Executable, Expertise-aware, Evolving, Discoverable; "Culture interprets policy" (State report p. 32–33).

Its playbook for measurement (State report p. 39–41): do not average metrics across unlike systems; ask did we build the right thing, did we build it right, did we get it to the right people, quickly and adaptably; and four rules — "The best data is the data used every day", "Manage to mission value, not metrics", "Don't rely on a single metric", "Data can be aggregated, but metrics can't".

CHAPTER

5

DevSecOps reference designs

5.1 Pathway to a Reference Design

Eight steps from community proposal to approved design: proposal, evaluation and differentiation, define interconnects, publish draft, execute pilot, lessons learned, SSG briefing, approved reference design (Pathway p. 2). A draft must build on the guidebook's REQUIRED items and "must be piloted in an operationally relevant environment" before approval; approved designs are living documents "revised no less than once per year" with an expiration banner (Pathway p. 3).

5.2 The four designs side by side

Table 5.1: Reference design comparison (each design's own statements).

	CNCF Kubernetes	Multi-Cluster K8s	AWS Managed (draft)	Azure + GitHub (draft)
Status	Approved, v2.1, Sep 2021; self-expiry printed (RD-K8s p. 1, 3)	Approved, v1.0, Jul 2022 (RD-Multi p. 1, 3)	Pre-decisional draft v0.2; approval TBD (RD-AWS p. 1, 3)	Pre-decisional draft v0.01 (signed Oct 2022) (RD-Azure p. 1–2)
Stance	Cloud-agnostic; container is the unit of deployment; K8s in production (RD-K8s p. 7)	Many small clusters, shared services, forward-deployable management (RD-Multi p. 7, 10)	"not vendor or product-agnostic"; deep AWS managed services (RD-AWS p. 9–10)	CSP-native SaaS + IaC; "does not cover containers" (RD-Azure p. 7, 9)
Platform	CNCF Certified K8s, Iron Bank hardened containers (RD-K8s p. 11, 18)	Conformant K8s with Cluster API lifecycle (RD-Multi p. 9)	EKS, ECR, App Mesh (RD-AWS p. 12–13)	DoD Cloud IaC on Azure Government; GitHub (RD-Azure p. 8–9)
North–south	Cloud Native Access Point (RD-K8s p. 11)	Delegated authentication within an accreditation boundary (RD-Multi p. 8)	CNAP (RD-AWS p. 12)	CNAP via Azure AD, Firewall, App Gateway/WAF or Front Door (RD-Azure p. 19)
East–west	Service mesh; sidecar security stack mandatory (RD-K8s p. 11)	mTLS between and within clusters (RD-Multi p. 10, 17)	App Mesh mTLS (RD-AWS p. 15)	Private endpoints, firewall hub (RD-Azure p. 52)

	CNCF Kubernetes	Multi-Cluster K8s	AWS Managed (draft)	Azure + GitHub (draft)
CI/CD	Orchestrator with stage entrance/exit control gates (RD-K8s p. 18–19)	Continuous reconciliation from a central source of truth (RD-Multi p. 12–14)	Pipeline with the main branch; CDK/-CloudFormation (RD-AWS p. 11)	GitHub Actions; GitHub-hosted or self-hosted runners (RD-Azure p. 23, 30–33)
Monitoring	SIEM/SOAR; CSP services "both/and" (RD-K8s p. 30–31)	Production-ready K8s even in development (RD-Multi p. 10, 19)	CloudEvents, EventBridge, Security Hub (RD-AWS p. 13)	Monitor, Defender for Cloud, Policy, Sentinel (RD-Azure p. 14–15)
Notable	Two different container scanners REQUIRED (RD-K8s p. 25)	"No in-place patching" (RD-Multi p. 10)	No SSH or RDP; HTTPS only (RD-AWS p. 11)	"code low, deploy high" (IL2 dev, IL4/5 prod) (RD-Azure p. 8)

5.3 The Azure + GitHub draft in more detail

Because the Azure draft is the closest to a cloud-hosted, SaaS-tooled team, its specifics are worth knowing even though it is a draft and names GitHub rather than any other tool.

- Three design elements: Infrastructure as Code builds the cloud environment; a CSP-managed development suite as a service; applications from CSP-native services secured by policy (RD-Azure p. 8–9).
- The DoD Cloud IaC baseline has a DISA provisional ATO; inheritance from the PaaS and IaaS layers "accounts for approximately 40% of all controls"; systems "must still be assessed for a full ATO" (RD-Azure p. 7, 10, 19). The baselines are updated monthly and are Distribution C (US Government and contractors) (RD-Azure p. 20).
- Prerequisites: an empty Azure AD tenant, an Enterprise Agreement with five named subscriptions (Operations, Development, Test, Production, Forensics); pay-as-you-go subscriptions are incompatible (RD-Azure p. 16).
- Runners: GitHub-hosted runners in Azure Commercial for workloads up to IL5, or self-hosted runners inside the Azure Government environment, which poll outward over authenticated HTTPS so artifacts never leave the secured environment (RD-Azure p. 30–33). Use OpenID Connect federation instead of long-lived cloud credentials in the CI secret store (RD-Azure p. 34–35).
- Pipeline minimums: linters, security checks, code coverage, functional checks; a periodic (weekly or daily) build so scanning happens even without changes (RD-Azure p. 29–30). IL6 and air-gapped clouds need a self-hosted server product (RD-Azure p. 70).

> **For a small MBSE team: GitLab Dedicated on Azure with AKS runners**
>
> No reference design in the library names GitLab. The cATO guide lists "an existing commercial integrated DevSecOps tool" among its options for a platform (cATO guide p. 15), and the Azure draft's patterns carry over by analogy: runners inside your own Azure subscription that poll outward (a GitLab runner with the Kubernetes executor on AKS does this), short-lived federated credentials instead of stored secrets, private repositories at IL4 and above, a scheduled pipeline that scans even when nothing changed. Which reference

> design your platform claims conformance to is a question for your platform team and AO, because cATO requires one (cATO criteria p. 14) (Primer: *Runners: where the pipeline runs*). Terraform is named in the Playbook as cloud-agnostic IaC that trades vendor lock-in for product lock-in (Playbook p. 5).

CHAPTER

6

Open source software

What it is. The DoD CIO memorandum of 24 January 2022, which supersedes the 2009 open source memo (OSS memo p. 1–2). POLICY DoWI 8430.01 adds the 2026 rules (sections 3.5.i and 3.7) (DoWI 8430.01 p. 21–26).

Two concerns frame it: externally maintained code is a path for malicious code, so open source needs the same supply chain risk management as any product; and imprudent sharing of DoD code helps adversaries, which a modular open systems approach manages by separating the critical parts (OSS memo p. 1).

Table 6.1: Open source rules.

Rule	Source
Adopt, Buy, Create: existing government or open source first, then proprietary, new software last.	(OSS memo p. 3); (DoWI 8430.01 p. 10)
Open source is commercial computer software and gets equal consideration; refusing it only because it is open source may restrict competition.	(OSS memo p. 3)
Program managers own the suitability of off-the-shelf components, including open source.	(OSS memo p. 3)
Assess: long-term support (project health), trusted sources, dependencies, component security, integrity (signatures), foreign influence.	(OSS memo p. 4–5); (DoWI 8430.01 p. 22)
For non-trivial open source, also governance and control model, community health and security practices, licence and legal risk.	(DoWI 8430.01 p. 22–23)
Respect the licence: most open source is copyrighted; keep authorship and licence notices.	(OSS memo p. 5)
Do not unduly restrict developers' access to software repositories.	(OSS memo p. 5)
Plan sustainment of open source components in the product support strategy.	(OSS memo p. 6)
Take delivery of source code and everything needed to build, test and deploy it.	(OSS memo p. 6)

Rule	Source
Non-NSS software is open by default unless it is critical technology, the government lacks rights, or export rules forbid release.	(OSS memo p. 7)
Distribution B–F software is CTI and may not be released as open source; software that is not is not CTI.	(OSS memo p. 7)
Acceptable licences: Apache-2.0, BSD, GPL, LGPL, MIT; no custom licences. (DoWI: permissive, widely recognized licences approved by a Military Department or the CIO.)	(OSS memo p. 7–8); (DoWI 8430.01 p. 26)
Contribute upstream by pull/merge request; avoid DoD-specific forks; employees may contribute as official duty after consulting their supervisor.	(OSS memo p. 8)
All third-party components and transitive dependencies go in the SBOM.	(DoWI 8430.01 p. 23)

For a small MBSE team: open source tools in a model pipeline

A team's toolchain (git, a scripting language, a SysML v2 grammar, a diagram tool) is open source under these rules: record each in the SBOM, assess its project health once, and keep the tool versions in the baseline. A kit written by the government team for a civilian, non-critical purpose is a candidate for release; anything with a military application is CTI from its inception (DoWI 8430.01 p. 14).

CHAPTER

7

Continuous authorization to operate

7.1 The memo

Signed 2 February 2022 by the DoD Senior Information Security Officer (cATO memo p. 3). POLICY RMF practice focused on obtaining ATOs and fell short on continuous monitoring (cATO memo p. 1). To achieve cATO the AO must demonstrate three competencies: on-going visibility with robust continuous monitoring of RMF controls; active cyber defense in real time; and "the adoption and use of an approved DevSecOps reference design" (cATO memo p. 1). "Simply conducting scans and patching does not meet the threshold for active cyber defense" (cATO memo p. 2). The AO and component CISO present the request and evidence to the DoD CISO; approved cATOs "do not have an expiration date" while the posture holds; the cATO does not replace the underlying ATO and can be revoked without losing it (cATO memo p. 2–3).

7.2 The evaluation criteria and the implementation guide

Two use cases (cATO criteria p. 5–6): (1) inside the software factory boundary — the factory's own production environment, "the main use case"; (2) outside it — software deployed into another authorization boundary (for example a weapon system) under a memorandum of understanding and interconnection security agreement.

Prerequisites. All RMF steps followed and the system in the RMF Monitor step (cATO criteria p. 6); a current ATO "with no 'High' or 'Very High' unmitigated findings" (cATO criteria p. 8); a robust continuous monitoring strategy with automated triggers on approved thresholds (cATO criteria p. 7). Cloud hosting "requires the deployment of a Cloud Native Application Protection Platform (CNAPP)" (cATO criteria p. 7).

Assessment. Platform, process and people are assessed against the three competencies (cATO criteria p. 9); evidence includes demonstrations, interviews and tracking systems (cATO guide p. 9–10). The guide's practical advice: use an existing platform before building one — building new "is the most time-consuming approach, and it should be avoided if possible"; bring security into the team at the start; continuous monitoring in all environments, including development and test; user stories and frequent demonstrations "rather than creating comprehensive requirements"; no waterfall and no heavy-weight agile process (cATO guide p. 15–16).

Metrics. Mean time to patch; guardrail and control-gate trends sprint over sprint; feedback frequency; mitigation effectiveness; security posture dashboards (cATO guide p. 14–15), (State report p. 30).

7.3 Checklist

Condensed from the evaluation criteria (cATO criteria p. 10–17). The criteria mark the package documents; this list is a reading aid, not the package.

Table 7.1: cATO evaluation checklist.

Continuous monitoring (cATO criteria p. 10–13)	
☐	cATO risk management strategy with risk tolerances, insider and external threats (DoDI 8510.01)
☐	System CONMON strategy: vulnerabilities tracked on all assets; implementation, effectiveness and impact measures; monitoring timelines; tied to audit and incident response
☐	Authorization boundary diagram with data flows (including PII) and all external connections
☐	Business rules: certified cyber staff, roles, a vulnerability POC, AO real-time access to test, scan and monitoring results
☐	Automated monitoring: a working near-real-time dashboard, alerting, reporting to CMRS, the pipeline itself monitored
☐	Authorization package (SAP, SAR, RAR, SSP, signed ATO, POA&Ms), with a security assessment covering the platform and delivery pipeline (threat modeling, pen testing, attack surface, manual code review, SAST, DAST, IAST)
☐	COOP/disaster recovery with test evidence; incident response plan with exercises
☐	Continuous vulnerability management with timelines; audit log analysis; the cATO approval memo template
Active cyber defense (cATO criteria p. 13–14)	
☐	Certified CSSP with SLA, sensors, and training on DevSecOps
☐	Third-party penetration test of development and operational environments within 90 days and annually
☐	Ongoing security testing against real adversary techniques; budget for automated cyber testing
Platform (cATO criteria p. 14–15)	
☐	Name the approved reference design the platform implements
☐	SBOM for the platform and an automated SBOM export for every product (SPDX, SWID or CycloneDX; the format "has not yet been mandated"); an SBOM archive; how new CVEs are applied to stored SBOMs
☐	Activities and Tools mapping of REQUIRED and PREFERRED activities, with a roadmap and demonstrations
☐	CNAPP: composition analysis, SAST/DAST/IAST, cloud posture and entitlement management, IaC scanning, workload protection, cloud detection and response
Process (cATO criteria p. 15–16)	
☐	IaC and configuration as code to prevent drift

- ☐ Each control gate described (what opens and closes it, alerts, responses) and demonstrated; each guardrail and its out-of-tolerance process

People (cATO criteria p. 16–17)

- ☐ Role-based training records; org chart; separation of duties and least privilege
- ☐ Tabletop exercises with after-action reports (incidents, gate triggers, alerts, privilege requests)
- ☐ Team trained on the reference design, tools, gates and tolerances, adjudication, root cause analysis, POA&Ms and dashboards
- ☐ Insider threat working group; onboarding and offboarding for everyone regardless of rank

For a small MBSE team: cATO

A small model team rarely seeks its own cATO; it builds on a platform that has (or is pursuing) one, and inherits most of the platform controls. What it owns is in its repository: control gates that are documented and demonstrable (the pipeline jobs and their failure messages), an SBOM and an archive of them per baseline, findings tracked to closure in the backlog, and training records. Ask the platform team for its reference design, its risk tolerances and how a pipeline failure is routed (Primer: *Security: protect the environment, engineer it into the system*).

CHAPTER

8

What it means for a small MBSE team

This chapter is this guide's reading, not the Department's. It assumes a team like the MBSE-DEVSECOPS Primer's: a few systems engineers keeping a SysML v2 text model in GitLab Dedicated, runners on Kubernetes (AKS) in an Azure subscription, the environment defined in Terraform, work arriving as requests from another system.

Table 8.1: From obligation to practice.

The documents ask	A model team does	Primer chapter
Testable requirements traceable to mission functions (DoWI 8430.01 p. 4–5)	Requirements as model elements with satisfy and verify links, checked on every merge request	Requirements a pipeline can check
Operate a secure CI/CD pipeline (DoWI 8430.01 p. 9)	Every model change through a merge request and a pipeline; protected branches	The pipeline, job by job
Testing is continuous, not a final gate (DoWI 8430.01 p. 14)	Grammar, lint, trace and verification-matrix jobs on every change; results kept as evidence	CI/CD from zero
Configuration management discipline (Guidebook p. 15)	Baselines as tags, audited by checksum; the change history in git	Maintenance through the life cycle
SBOM and provenance (DoWI 8430.01 p. 18)	Record the toolchain (versions and checksums) with each baseline; generate an SBOM for any software produced	Security: protect the environment
Value stream metrics; DORA inside the team (DoWI 8430.01 p. 15–16)	Lead time from request to merged change and to baseline; deployment frequency of baselines; failure rate of pipelines	Measuring with GitLab analytics
Engage users; demonstrate (DoWI 8430.01 p. 10)	Sprint reviews that demonstrate the model, not slides about it	The rhythm
AI code is unverified input (DoWI 8430.01 p. 23)	Review every AI-drafted change like any other; label it; keep the assistant on an approved system	A local AI assistant on the laptop
Use an existing platform (cATO guide p. 15)	Use the enterprise GitLab and runners; add jobs, not infrastructure	Setting up GitLab; Runners

The documents ask	A model team does	Primer chapter
Infrastructure as Code (Strategy p. 11)	Keep the project's own settings (labels, boards, schedules) as code; leave the cluster's Terraform to the platform team unless you own it	Administration

What not to over-read

None of the documents requires a particular tool, a SysML language or a model repository. The guidebook says common tools are "a class of tooling" and not the same product everywhere (Fundamentals p. 20). The DORA metrics and the twelve-week scorecard are team diagnostics; reporting upward should be in mission terms (DoWI 8430.01 p. 16), (State report p. 41).

CHAPTER

9

What to read in full, and when

Table 9.1: Reading plan.

Who	Read in full	When
Everyone on the team	DevSecOps Fundamentals (44 pp.); DoWI 8430.01 section 3 (pp. 13–29)	In the first two weeks
Systems engineering lead	DoWI 8430.01 in full; Activities & Tools Guidebook Plan, Develop and Test tables	Before the first planning meeting; again before a review
Whoever owns the pipeline	Guidebook and workbook in full; the reference design your platform implements	Before writing the pipeline; when the platform changes
Security and the ISSM	cATO memo, evaluation criteria, implementation guide; DoWI 8430.01 section 3.5	Before the authorization conversation
Program manager	Strategy; Implementation Plan; State of DevSecOps sections 5 and 8; DoWI 8430.01 sections 3.3 and 3.8	Before setting measures and contracts
Anyone choosing a tool or library	OSS memo; DoWI 8430.01 section 3.5.i	Before adopting it
Anyone using an AI assistant	DoWI 8430.01 section 3.6	Before the first use
For background only	Playbook, Pathway, SWFT memo and RFI summary, AWS draft	When the topic comes up

CHAPTER

A

Glossary of acronyms

ACD
Active Cyber Defense
AO / AODR
Authorizing Official / AO Designated Representative
ATO / ATC
Authorization to Operate / to Connect
cATO
Continuous Authorization to Operate
CI/CD
Continuous Integration / Continuous Delivery (or Deployment)
CISO
Chief Information Security Officer
CM / CMDB
Configuration Management / CM Database
CNAP
Cloud Native Access Point
CNAPP
Cloud Native Application Protection Platform
CNCF
Cloud Native Computing Foundation
CONMON
Continuous Monitoring
CSSP
Cybersecurity Service Provider
CTI
Controlled Technical Information
CUI
Controlled Unclassified Information
DAST / SAST / IAST
Dynamic / Static / Interactive Application Security Testing
DCWF
DoD (DoW) Cyber Workforce Framework
DITPR
DoD IT Portfolio Repository
DORA
DevOps Research and Assessment
DSOP
DevSecOps Platform
DT&E / OT&E
Developmental / Operational Test and Evaluation
E2P
Exception to Policy
IaC / CaC
Infrastructure / Configuration as Code
IL
Impact Level (cloud security requirements guide)
ISA / MOU
Interconnection Security Agreement / Memorandum of Understanding
ISCM
Information Security Continuous Monitoring
JWCC
Joint Warfighting Cloud Capability
MOSA
Modular Open Systems Approach
MVP / MVCR
Minimum Viable Product / Capability Release
NSS
National Security System
OSS
Open Source Software
POA&M
Plan of Action and Milestones
RAR / SAR / SAP / SSP
Risk Assessment Report / Security Assessment Report / Plan / System Security Plan
RMF / RMF KS
Risk Management Framework / its Knowledge Service
SBOM / SCA
Software Bill of Materials / Software Composition Analysis

SCSS
Sidecar Container Security Stack

SIEM / SOAR
Security Information and Event Management / Security Orchestration, Automation and Response

SSDF
Secure Software Development Framework (NIST SP 800-218); groups PO, PS, PW, RV

SSG
Software Modernization Senior Steering Group

SSSC
Secure Software Supply Chain

SWFT
Software Fast Track

SWP
Software Acquisition Pathway (DoDI 5000.87)

CHAPTER

B

Sources

The library page `https://dodcio.defense.gov/library/` as captured on 3 October 2026 (the live site did not answer automated requests when this guide was compiled). Pages are PDF pages. Checksums are SHA-256 of the copies read.

#	Document, address, version, pages, SHA-256
1	**DoW Software Modernization Strategy** — `https://dodcio.defense.gov/Portals/0/Documents/Library/SoftwareModStrat.pdf` — v1.0 Nov 2021, memo 1 Feb 2022 — 14 pp. — `0276c47b7fb058e660bdacce2ca621e93a8cea78e290a7b05f9f581b8a02b53a`
2	**Software Modernization Implementation Plan FY25–26** — `https://dodcio.defense.gov/Portals/0/Documents/Library/SW-Mod-I-Plan25-26.pdf` — cleared 30 Apr 2025 — 27 pp. — `ba350c72245b8efac4a0e4a5655f4042e9a53b6e8a1fa44dbe3170bae0122601`
3	**DoWI 8430.01, Accelerated Mission Software** — `https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/843001p.pdf` — effective 8 Sep 2026 — 37 pp. — `b35f0dcc2fae721994413c702671e9b754ed6911daeecfcfec0d83f0a4df465a`
4	**Memo: Accelerating Secure Software** — `https://dodcio.defense.gov/Portals/0/Documents/Library/Memo-AcceleratingSecureSoftware.pdf` — 24 Apr 2025 — 1 p. — `2010080899dceab07f1dd9caa48ed5cfba6d921eccc34cd5a7b790efdabdea13`
5	**Software Fast Track RFI Combined Summary** — `https://dodcio.defense.gov/Portals/0/Documents/Library/SWFT-RFI-Combined-Summary.pdf` — cleared 3 Dec 2025 — 31 pp. — `a2a2ad2a36b9e336775e567e3a6c60ba6745f8ef204d5bf9ab0066dfc06825b1`
6	**DoW Enterprise DevSecOps Fundamentals** — `https://dodcio.defense.gov/Portals/0/Documents/Library/DoD%20Enterprise%20DevSecOps%20Fundamentals%20v2.5.pdf` — v2.5, Oct 2024 — 44 pp. — `dbef8ab70c33aade3d6495970caad09f46f750482625e8ad22400c7b1eddb22b`
7	**DoW Enterprise DevSecOps Activities & Tools Guidebook** — `https://dodcio.defense.gov/Portals/0/Documents/Library/DevSecOpsActivitesToolsGuidebook.pdf` — v2.5, Apr 2025 — 65 pp. — `350432bf6bc046a8a0ab5e5ece352386dabcb8a7921c54fcacd9b49897224143`
8	**DevSecOps Fundamentals Guidebook: Activities & Tools (xlsx)** — `https://dodcio.defense.gov/Portals/0/Documents/Library/DevSecOpsActivitesToolsGuidebookTables.xlsx` — companion of v2.5 — 14 tabs — `60c330c7659d2fa242deba078722c5c8242883c9c02cc0f147506c2459b623a9`
9	**DevSecOps Playbook** — `https://dodcio.defense.gov/Portals/0/Documents/Library/DevSecOps%20Playbook_DoD-CIO_20211019.pdf` — v2.1, Sep 2021 — 14 pp. — `809a6fbb462aeeec20b4db087b3feddf084dcd9ff855842e7b18e990ce882554`
10	**The State of DevSecOps Report** — `https://dodcio.defense.gov/Portals/0/Documents/Library/DevSecOpsStateOf.pdf` — Mar 2025 — 47 pp. — `66a647df3b1b1bf837e430e5aff1fb4b0a0370979ff55ec4d30f0c9a11f3874e`

#	Document, address, version, pages, SHA-256
11	**Reference Design: CNCF Kubernetes** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20-%20CNCF%20Kubernetes%20w-DD1910_cleared_20211022.pdf — v2.1, Sep 2021 — 32 pp. — 9742f6a5d6ca6b32ca30c6857a61e3d35d009141df2d5e6891a77eaf7164a117
12	**Reference Design: CNCF Multi-Cluster Kubernetes** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoDReferenceDesign-CNCFMulti-ClusterKubernetes.pdf — v1.0, Jul 2022 — 28 pp. — addad98c2d19c620f4ef0260687595b731e0d11fb9eef93f9fe3e460ef7ffef1
13	**DRAFT: DOW AWS Managed Service** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20-%20AWS%20Managed%20Services_DoD-CIO_20211019.pdf — v0.2, Sep 2021 — 35 pp. — 0041626903b05b2cd8fbb3e8aa323fe5de4624d29148d17425498bc0aeabef9e
14	**DRAFT: DOW Cloud IaC + GitHub + Azure** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoDRefDesignCloudGithub.pdf — v0.01, Sep 2022 — 70 pp. — 2e2e896d30588754cc0be268ac896b0e5c8b35df6c93a843a990ff633838fc0d
15	**Pathway to Reference Design** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoD%20Enterprise%20DevSecOps-Pathway%20to%20a%20Reference%20Design_DoD-CIO_20211018.pdf — Sep 2021 — 3 pp. — 0e4b2f85eb0d8eaeda3098f7aa4c2ba17298fcb1b36792aa19952e0934ca733b
16	**Software Development and Open Source Software Memorandum** — https://dodcio.defense.gov/Portals/0/Documents/Library/SoftwareDev-OpenSource.pdf — 24 Jan 2022 — 8 pp. — 8113f7c6321f5adf549de678bfc8bfb60fd784b03cbcf73d34f88ae7e6345cff
17	**Memo: Continuous Authorization to Operate (cATO)** — https://dodcio.defense.gov/Portals/0/Documents/Library/20220204-cATO-memo-Signed-Cleared.pdf — 2 Feb 2022 — 3 pp. — c366edb4bd0174574c12dae25362a40cd7428f871dc2a0676cf76d2da6580c90
18	**DevSecOps cATO Evaluation Criteria** — https://dodcio.defense.gov/Portals/0/Documents/Library/cATO-EvaluationCriteria.pdf — 29 May 2024 — 19 pp. — afbe0a13a7f63c8741d036d373508c93ae1c9df1abb37ddf74714f1b43052608
19	**DevSecOps Continuous Authorization Implementation Guide** — https://dodcio.defense.gov/Portals/0/Documents/Library/DoDCIO-ContinuousAuthorizationImplementationGuide.pdf — v1.0, Mar 2024 — 26 pp. — 4218c2c20efd5002ea107e1f74d9e7777009fe9efe66f04a5bbaba142918712a